

WorkWise

セキュリティ仕様書

TOYOTA MOBILITY PARTS KANAGAWA BRANCH

1. 概要

本ドキュメントは、WorkWise アプリケーションにおける Google Cloud Firestore（データベース）のセキュリティルール、およびアプリケーションレベルでのロールベース権限管理（RBAC: Role-Based Access Control）について定義・解説するものです。

---

2. セキュリティの階層構造

本システムのセキュリティは、強固な防御を実現するため以下の2層で管理されています。

---

3. データベース層のセキュリティルール (Firestore)

Firestore のセキュリティルールでは、「Firebase Authentication による認証済みユーザー」であることを基本要件とし、コレクションごとにきめ細やかなアクセス制御を行っています。

コレクション別セキュリティポリシー

コレクション | 読み取り (Read) | 作成・更新 (Write) | 削除 (Delete) | 備考

`orders` | 認証済みユーザー | 認証済みユーザー (Admin/Staff) | 管理者のみ (Admin) | 受注・案件情報

`users` / **`staff`** | 認証済みユーザー | 管理者 / 本人のみ | 管理者のみ (Admin) | スタッフマスタ・プロファイル

`customers` | 認証済みユーザー | 管理者のみ (Admin) | 管理者のみ (Admin) | 販売店・顧客マスタ

`workSchedules` | 認証済みユーザー | 管理者のみ (Admin) | 管理者のみ (Admin) | 月間シフトデータ

`daily_attendance` | 認証済みユーザー | 認証済みユーザー (打刻) | 管理者のみ (Admin) | 日次勤怠・出勤退勤ログ

`employeeActions` | 認証済みユーザー | 認証済みユーザー (ログ追加) | 管理者のみ (Admin) | 現場進捗アクションログ

`counters` | 認証済みユーザー | 認証済みユーザー (採番更新) | 管理者のみ (Admin) | 受注ID等の自動採番

---

4. アプリケーション層のロール別権限 (RBAC)

アプリケーション層では、ユーザープロファイル内の `role` フィールド（`admin` または `staff`）に基づいて機能の利用可否を制御しています。

権限マトリクス

機能 / 画面 | 管理者 (Admin) | 現場スタッフ (Staff)

ダッシュボード (全体スケジュール閲覧) | ○ (全スタッフ) | ○ (閲覧可能)

オーダーのドラッグ＆ドロップ割当（受注割当） | ○ | × (操作不可)

受注管理 (`/orders`) - 一覧・インライン編集 | ○ | × (アクセス制限)

新規受注登録 (`/order-form`) | ○ | ○ (登録可)

スタッフ管理 (`/staff`) - 編集・追加 | ○ | × (自身の情報のみ閲覧)

月間シフトのインポート (`/staff`) | ○ | × (操作不可)

販売店情報 (`/customers`) - 編集 | ○ | × (閲覧のみ)

データ一括インポート (`/import`) | ○ | × (アクセス制限)

分析レポート (`/admin/analytics`) | ○ | × (非表示・アクセス制限)

ルート最適化 (`/optimizer`) | ○ | ○ (担当ルート確認)

現場チェックイン (`/check-in`) - 打刻・進捗報告 | ○ | ○ (主要機能)

緊急連絡の受信・返信・解除 | ○ (返信・解除可) | ○ (送信のみ)

---

5. データ保護とコンプライアンス

- 通信の暗号化: すべてのデータ通信は TLS 1.3 / HTTPS により暗号化されています。
- パスワードの安全性: Firebase Authentication により、パスワードは強固なハッシュ化アルゴリズム（Scrypt）で保護され、平文で保存されることはありません。
- 位置情報 (GPS) の取り扱い: 現場スタッフの業務中（出勤〜退勤の間）のアクション時のみ位置情報を取得・記録し、プライバシー保護と業務効率化を両立しています。